

Coconut 제품 설명서

계정과 로그인, 인증 정책을 한곳에서 관리합니다.

서비스의 인증을 연결하고, 운영자가 관리할 수 있도록.

Coconut은 고객사와 연동 서비스를 구분하고, 사용자 인증과 토큰 설정, 계정 상태 및 운영 이력을 관리하는 인증·계정 관리 솔루션입니다.

계정 관리

고객사·사용자·관리자의
정보와 관리 범위를 구분합니다.

서비스 연동

OAuth 2.0·OIDC 기반으로
서비스의 로그인을 연결합니다.

운영과 보안

로그인 이력·감사 로그와
보안 정책을 확인합니다.

개요 · 계정 관리, 고객 직접 관리 콘솔, 표준 인증 연동, 운영 모니터링을 제공합니다. 화면의 수치는 이해를 돕기 위한 예시 데이터입니다.

제품 구성과 주요 용어

테넌트는 고객사 구분, 클라이언트는 로그인 기능을 연결하는 서비스입니다.

구분	쉽게 풀어 쓴 의미	관리 화면에서 확인하는 내용
테넌트	고객사 또는 서비스를 구분하는 관리 단위	이름·유형·플랜·상태
클라이언트	Coconut에 인증을 맡기는 웹·앱·API 서비스	인증 방식·스코프·콜백·토큰·브랜딩
사용자	연동 서비스에 로그인하는 계정	상태·소속·로그인·인증 정보
관리자	계정과 설정을 관리하는 운영 계정	시스템 전체 또는 지정 테넌트의 관리 범위

OAuth 2.0은 접근 권한을 위임하는 표준, OIDC는 로그인한 사용자의 신원을 확인하는 표준입니다. 토큰은 인증·인가 결과를 서비스에 전달하는 값이며, 스코프는 요청하는 접근 범위입니다.

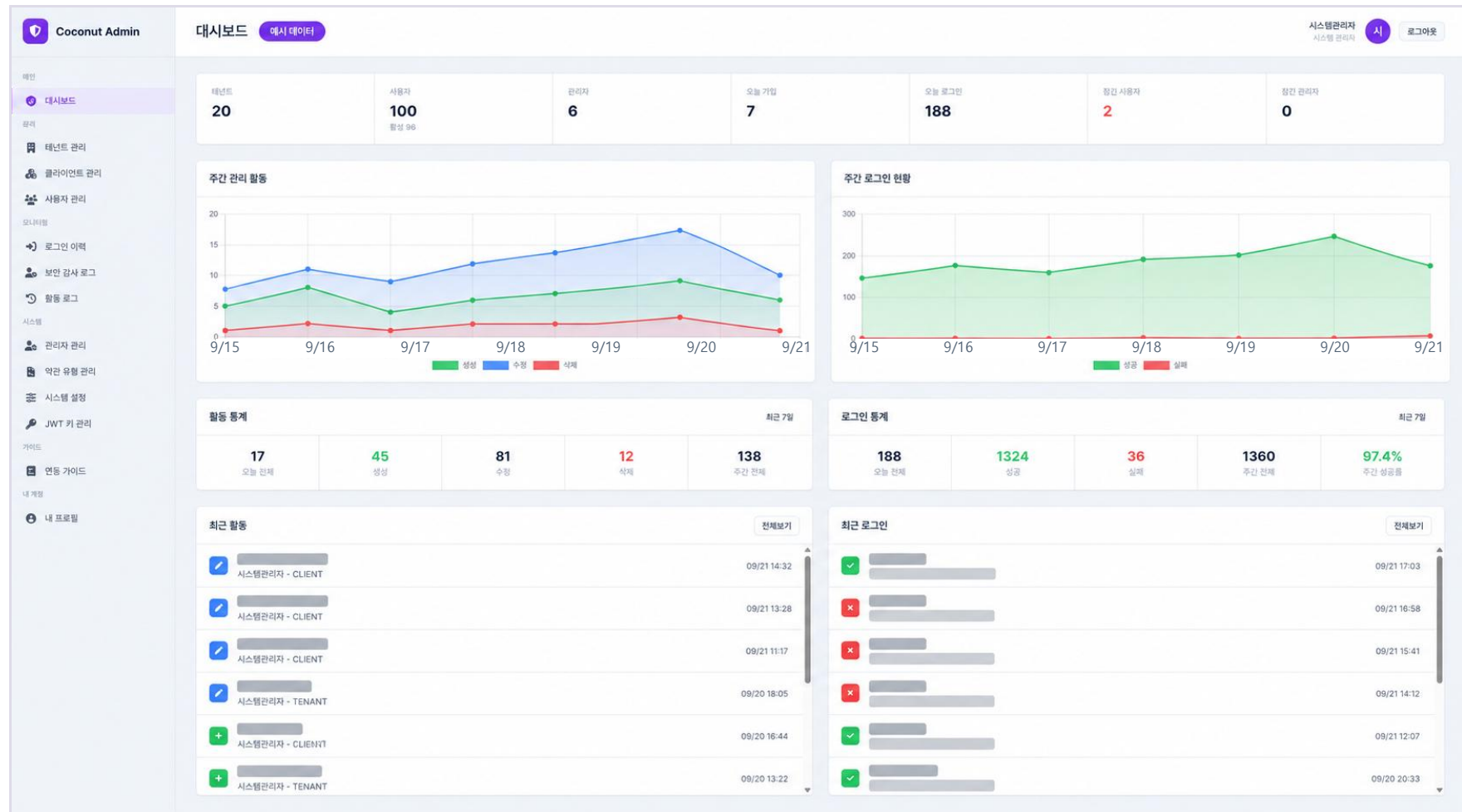
로그인 처리의 기본 관계



서비스의 메뉴·업무·데이터 권한은 연동 서비스가 적용합니다. Coconut의 계정 인증과 업무 권한은 구분합니다.

대시보드

계정 현황과 최근 로그인·관리 활동을 한 화면에서 확인합니다.



예시 데이터 · 개인정보 비공개. 계정 현황과 접속 추이를 함께 살펴보고 최근 관리 활동을 확인합니다.

고객사와 관리자 관리

고객사 단위의 정보와 운영 담당자의 관리 범위를 구분합니다.

관리 영역	주요 기능	사용 목적
테넌트 목록	이름 검색, 상태 필터, 활성화·비활성·정지·삭제 구분	고객사 현황을 찾고 관리 대상 확인
테넌트 정보	식별자, 이름, 도메인, 유형, 플랜, 생성일	고객사별 구성 정보 관리
관리자 목록	검색, 상태, 시스템·테넌트 유형, 관리 범위	운영 계정과 담당 범위 확인
운영 역할	시스템 관리자 / 지정 테넌트 관리자	관리 책임을 구분하여 운영

고객사 단위의 관리 체계

고객사 정보를 테넌트로 구분하고 사용자와 연동 서비스를 연결합니다. 관리자는 자신에게 부여된 범위에 따라 운영 업무를 수행합니다.

시스템 관리자와 테넌트 관리자의 담당 범위를 구분해 운영합니다. 고객사가 직접 쓰는 고객 콘솔은 다음 쪽에서 설명합니다.

셀프서비스 고객 콘솔

고객사 담당자가 공통 회원가입 후 조직을 만들고, 구성원과 함께 테넌트와 연동 서비스를 직접 관리합니다.

조직 역할	적용 범위	할 수 있는 일
소유자 (OWNER)	조직 전체	조직 전체 조회·관리, 테넌트 생성, 구성원 초대·권한 회수
관리자 (MANAGER)	조직·테넌트·클라이언트 중 지정 범위	지정 범위 조회·수정, 하위 테넌트·클라이언트 생성
조회자 (VIEWER)	조직·테넌트·클라이언트 중 지정 범위	지정 범위 조회

관리 영역	고객 콘솔에서 하는 일
조직과 구성원	조직 생성·선택, 범위별 초대·권한 회수·초대 취소, 사용량 조회
테넌트와 클라이언트	생성과 이름 수정, 클라이언트 OAuth 인증 설정, 가입 방식·이메일 인증 설정
테넌트 사용자	등록 사용자 조회, 상태 변경, 잠금 해제

조직 역할은 앞 쪽의 시스템·테넌트 관리자 역할과 별개입니다. 소셜 로그인·MFA 같은 고급 인증 설정과 리소스 삭제는 현재 고객 콘솔에서 제공하지 않습니다.

초대는 초대받은 이메일로 인증한 계정만 수락할 수 있습니다. 신규 조직은 Coconut 운영자가 이용 한도를 설정한 뒤 사용을 시작합니다.

사용자 계정 관리

사용자를 검색하고 상태·소속·로그인 정보를 확인합니다.

100
전체

96
활성

3
비활성

1
정지

2
잠금

0
삭제됨

전체 사용자

잠긴 계정

삭제된 사용자

이름, 이메일, 사용자명 검색...

전체 상태

전체 테넌트

검색

초기화

+ 사용자 추가

사용자명	이름	이메일	테넌트	상태	최근 로그인	가입일	액션
				ACTIVE	2026-09-08 00:50	2026-09-08	상세
				ACTIVE	2026-09-08 00:27	2026-09-05	상세
				ACTIVE	2026-09-10 00:42	2026-09-03	상세
				ACTIVE	2026-02-20 17:26	2026-02-20	상세
				ACTIVE	2026-08-26 23:11	2026-02-20	상세
				ACTIVE	-	2026-02-20	상세
				ACTIVE	-	2026-02-20	상세
				ACTIVE	-	2026-02-20	상세
				INACTIVE	-	2026-02-20	상세
				ACTIVE	-	2026-02-20	상세
				ACTIVE	2026-09-21 16:17	2026-02-20	상세
				ACTIVE	-	2026-02-20	상세

상세 화면: 계정 상태, 로그인 실패 횟수, 잠금 여부, 본인인증 정보와 계정 관리 항목을 확인할 수 있습니다.

화면 기반 보정 이미지 · 예시 통계. 이름·사용자명·이메일·고객사 식별정보는 가렸습니다. 목록은 일부 계정의 표시 예시입니다.

클라이언트 등록과 설정

웹·앱·API 서비스를 등록하고 서비스에 맞는 인증 정책을 구성합니다.

기본 정보

테넌트 *

선택하세요

앱 이름 *

예: employee-web

영문 소문자, 숫자, 하이픈(-)만 사용. 생성 후 변경 불가.

Client ID: -

클라이언트 이름 *

예: Test Employee Portal

사용자에게 표시되는 이름

클라이언트 타입 *

CONFIDENTIAL

Confidential: 서버 앱 (시크릿 사용) / Public: SPA, 모바일 (PKCE 사용)

OAuth2 설정

Grant Types *

☐ AUTHORIZATION_CODE
 ☐ REFRESH_TOKEN
 ☐ CLIENT_CREDENTIALS

Scopes *

사용할 Scope를 선택하고, 필수 동의가 필요한 Scope는 '필수' 체크박스를 선택하세요.

선택	SCOPE	설명	필수
☐	openid OpenID	사용자 고유 식별자(sub)에 접근합니다	☒
☐	profile 프로필	이름, 프로필 사진 등 기본 정보에 접근합니다	☐
☐	email 이메일	이메일 주소 및 인증 여부에 접근합니다	☐
☐	phone 전화번호	전화번호 및 인증 여부에 접근합니다	☐
☐	address 주소	주소 정보에 접근합니다	☐
☐	offline_access 오프라인 접근	Refresh Token을 발급받아 오프라인에서도 접근합니다	☐
☐	iam:system 시스템 관리	시스템 전체 관리 권한 (테넌트/역관유형/관리자계정/재시보드/로그)	☐

주요 항목: 소속 테넌트, 서비스 이름, 클라이언트 유형, 인증 흐름, 요청 스코프, 로그인 보호 설정

신규 설정 화면 예시 · 실제 계정과 비밀번호를 포함하지 않습니다. 연결 주소는 고객 환경에 맞게 별도로 등록합니다.

인증과 토큰 정책

서비스 구조와 보안 요구에 맞게 인증 방식과 토큰 정책을 설정합니다.

설정 구분	주요 기능	설정의 목적
클라이언트 유형	서버형(Confidential) / 공개형(Public)	비밀값 보관이 가능한지에 따라 인증 방식 구분
인증 흐름	Authorization Code / Refresh Token / Client Credentials	사용자 로그인, 토큰 갱신, 서버 간 인증 구성
스코프	사용자 정보와 API 접근 범위 등록	서비스에서 필요한 정보와 요청 권한 구분
토큰 유효기간	접근 토큰·갱신 토큰·인가 코드의 유효기간	서비스 특성과 보안 정책에 맞는 사용 기간 설정
로그인 보호·동의	PKCE 필수, 동의 화면, 스코프 자동동의	코드 교환 보호와 사용자 동의 정책 구성
서명과 갱신	ID 토큰 서명 방식, 갱신 토큰 자동 교체(기본 적용)	토큰 검증, 갱신 토큰 재사용 차단

PKCE는 인가 코드가 가로채져도 토큰 교환을 보호하기 위한 절차입니다. 실제 적용 시 클라이언트 특성에 맞게 설정합니다.
갱신 토큰은 사용할 때마다 새로 발급되고 이전 토큰은 다시 쓸 수 없습니다. 재사용이 필요한 클라이언트만 개별로 허용합니다.

클라이언트별 설정을 관리할 수 있습니다. 실제 적용값과 토큰 갱신 방식은 클라이언트 유형 및 연동 구조에 따라 정합니다.

서비스별 로그인 화면 브랜딩

서비스의 이름과 디자인을 로그인·회원가입 화면에 반영하는 설정을 제공합니다.

영역	주요 설정
로고와 색상	로고, 다크모드 로고, 파비콘, 주요·보조·강조·배경·글자 색상
문구와 글꼴	글꼴, 로그인 제목·부제목·환영 메시지·도움말
화면 구성	로그인 템플릿, 회원가입 버튼, 비밀번호 찾기, 구분선
회원가입과 푸터	회원가입 제목·도움말, 푸터 문구·링크, 추가 CSS
미리보기와 반영	로그인·회원가입·동의 화면 미리보기 링크, 임시저장·게시·직접 저장

서비스별로 일관된 사용자 경험

로고와 색상, 서비스 이름과 안내 문구를 함께 구성합니다. 사용자는 로그인 화면에서도 자신이 이용하는 서비스를 구분할 수 있습니다.

브랜딩은 사용자 접점의 표시 설정입니다. 로그인 템플릿은 화면 안내상 저장 즉시 반영되며 임시저장·미리보기 대상과 구분됩니다.

약관 관리

서비스 이용약관과 개인정보 관련 동의 항목을 유형별로 관리합니다.

4
전체 유형

약관 유형 목록

+ 새 유형 추가

순서	유형 코드	유형명	용도	설명	사용 현황	관리
1	SERVICE	서비스 이용약관		서비스 이용에 관한 기본 약관	2개 약관	수정 삭제
2	PRIVACY	개인정보처리방침		개인정보 수집 및 이용에 관한 약관	1개 약관	수정 삭제
3	MARKETING	마케팅 정보 수신 동의		마케팅 및 홍보성 정보 수신에 관한 약관	1개 약관	수정 삭제
4	THIRD_PARTY	제3자 정보 제공 동의		제3자에게 개인정보를 제공하는 것에 관한 약관	0개 약관	수정 삭제

약관 유형 예시: 서비스 이용약관 · 개인정보처리방침 · 마케팅 정보 수신 동의 · 제3자 정보 제공 동의

유형별 코드와 표시 이름, 설명, 사용 현황을 확인할 수 있습니다. 클라이언트 상세에는 별도의 약관 관리 메뉴가 있습니다.

실제 화면 캡처. 유형별로 사용 현황을 확인하고, 새 유형 추가·수정 항목에 접근할 수 있습니다.

약관 용도와 표시 설정

약관을 사용하는 시점과 표시 순서를 구분해 운영합니다.

기본 정보

유형 코드 *

SERVICE

대문자, 숫자, 언더스코어만 사용 가능합니다 (예: SERVICE, PRIVACY_POLICY)

입력된 코드: -

유형명 *

서비스 이용약관

사용자에게 표시될 약관 유형 이름입니다

설명

이 약관 유형에 대한 설명을 입력하세요

관리자가 이해하기 쉽도록 설명을 추가하세요 (최대 500자)

약관 용도 *

회원가입 약관

회원가입 약관만 회원가입·로그인·OAuth2 등의 화면에 노출됩니다. 그 외 용도는 클라이언트 API로 조회·동의 처리합니다.

표시 순서

0

숫자가 작을수록 먼저 표시됩니다

취소

생성

약관 용도

회원가입 / 기능·서비스 이용 / 거래·구매 / 이벤트·캠페인으로 구분합니다.

회원가입용 약관은 가입·로그인·인증 동의 화면에 표시하며, 그 외 용도는 연동 서비스에서 API로 조회·동의 처리합니다.

신규 설정 화면 예시 · 유형 코드, 표시 이름, 설명과 순서를 설정합니다. 실제 이용 시점의 동의 처리는 서비스와 연계합니다.

보안 정책과 기본 설정

로그인 실패, 비밀번호, 세션과 기본 토큰 정책을 관리하는 화면입니다.

보안 설정

로그인, 비밀번호, 세션 관련 보안 정책

로그인 실패 시 계정 잠금 횟수

security_login_fail_lock_count

기본값: 5

5

초기화

계정 잠금 시간 (초)

security_login_lock_duration

기본값: 1800

1800

초기화

비밀번호 만료 기간 (일)

security_password_expire_days

기본값: 90

90

초기화

비밀번호 최소 길이

security_password_min_length

기본값: 8

8

초기화

세션 타임아웃 (초)

security_session_timeout

기본값: 3600

3600

초기화

OAuth 설정

OAuth2 토큰 기본 설정

Access Token 유효 시간 (초)

oauth2_token_access_token_validity

기본값: 3600

3600

초기화

Refresh Token 유효 시간 (초)

oauth2_token_refresh_token_validity

기본값: 604800

604800

초기화

사용자 설정

사용자 관련 기본 설정

신규 사용자 기본 상태

user_default_status

기본값: ACTIVE

ACTIVE

초기화

취소

변경사항 저장

정책 항목

로그인 실패 잠금 횟수·잠금 시간 / 비밀번호 만료·최소 길이 / 세션 타임아웃 / 토큰 유효시간 / 신규 사용자 기본 상태

설정 화면 예시 · 정책값은 고객 환경에 맞게 구성합니다. 시스템 기본값과 클라이언트별 설정을 함께 관리합니다.

로그인 이력 조회

로그인 성공·실패와 접속 이력을 검색하고 상세 기록을 확인합니다.

1360

전체 시도

1324

성공

36

실패

0

잠금

97.4%

성공률

검색

상태

시작일

종료일

기간

1개월

3개월

6개월

검색

초기화

로그인 이력

총 1360건

시간	사용자	테넌트	클라이언트	상태	IP 주소	로그인 방식	액션
2026-09-21 16:17:03				성공			상세
2026-09-21 16:16:33				실패			상세
2026-09-21 16:16:27				실패			상세
2026-09-21 16:16:20				실패			상세
2026-09-21 16:15:32				성공			상세
2026-09-10 00:42:23				성공			상세
2026-09-09 19:51:03				성공			상세
2026-09-09 19:33:37				성공			상세
2026-09-09 19:17:56				성공			상세
2026-09-09 18:25:27				성공			상세
2026-09-09 16:45:10				성공			상세
2026-09-09 16:38:04				성공			상세
2026-09-08 22:59:05				성공			상세

조회 항목: 기간, 사용자, 테넌트, 클라이언트, 결과, 접속 IP, 로그인 방식

예시 데이터 · 식별정보 비공개. 기간과 결과를 조건으로 접속 이력을 찾고 상세 기록을 확인합니다.

감사 이력과 서명 키 관리

로그인 이력과 관리 활동, 보안 이벤트를 목적에 맞게 구분합니다.

기능	주요 기능	활용
보안 감사 로그	이벤트 유형·카테고리·심각도·결과·기간 필터	관련 보안 이벤트를 분류하고 상세 기록 확인
활동 로그	관리자, 활동 유형, 대상 유형·ID, 설명, 시간	운영자가 수행한 관리 작업 추적
JWT 서명 키	RSA-RS256, ACTIVE-ROTATED-EXPIRED 상태 안내	새 토큰의 서명과 기존 토큰의 검증에 쓰는 키 관리
키 로테이션	새 키 생성(로테이션) 기능과 상태별 용도 안내	키 교체 시 적용 범위와 검증 절차 확인

토큰의 신뢰를 유지하는 키 관리

서명 키의 상태와 생성 정보를 확인하고 교체를 관리합니다. 외부 서비스에서는 공개 키 확인, 검증용 키 캐시와 토큰 폐기 반영 정책을 함께 구성합니다.

로그인 이력, 보안 이벤트, 관리자 활동은 각각의 목적에 맞게 조회합니다. 필요한 기록 범위와 보관 정책은 운영 시 정합니다.

연동 서비스와 계정 보안

계정 상태 변화를 연동 서비스에 알리고, 사용자가 자기 계정의 보안 상태를 확인하는 공통 화면을 제공합니다.

기능	주요 내용	연동 서비스에서 할 일
사용자 이벤트 웹훅	상태 변경·삭제·복원·세션 종료 이벤트를 서명해 전달	서명·중복 확인 후 계정·세션에 반영
전달 재시도	실패하면 간격을 늘려 재시도, 한도를 넘긴 건은 운영자가 재전송	같은 이벤트가 다시 와도 한 번만 처리
세션 조회·종료	관리자가 세션을 조회하고 전체 또는 선택한 한 건을 종료	종료 이벤트를 받아 서비스 로그인 종료
공통 계정 보안 화면	이메일 인증·OTP 앱 등록 상태, 비밀번호 변경, 내 로그인 세션 조회	서비스 메뉴에서 이 화면으로 연결

이벤트 누락에도 대비하는 연동

웹훅을 구독하는 서비스의 접근 토큰 유효시간은 5분 이하로 둡니다. 이벤트가 늦거나 누락돼도 토큰이 곧 만료되고, 토큰을 갱신할 때 Coconut이 현재 계정 상태를 다시 확인합니다.

웹훅은 최소 1회 전달 방식입니다. 연동 서비스가 받은 이벤트로 자체 세션을 종료해야 기존 로그인까지 차단됩니다.

도입과 서비스 연동

계정과 인증은 Coconut이, 서비스 고유의 업무와 데이터 권한은 연동 서비스가 담당합니다.

순서	주요 작업
1. 적용 대상 정리	고객사 구분, 사용자 종류, 관리자 범위와 연동 서비스를 정합니다.
2. 클라이언트 구성	인증 방식·콜백·스코프·PKCE·토큰 유효기간을 설정합니다.
3. 로그인 연결	서비스 로그인 요청 → Coconut 인증 → 인가 코드 → 토큰 확인 순서로 연결합니다.
4. 서비스 권한 적용	연동 서비스가 사용자 소속과 업무·데이터 이용 권한을 확인하고, 계정 이벤트 웹훅을 받아 반영합니다.
5. 운영 검수	오류·권한 거부·세션 종료·로그·백업·복구를 실제 환경에서 검수합니다.

제공 범위의 구분

관리자 포털에는 OAuth2/OIDC 연동 가이드와 Spring Boot·JavaScript 예시가 있습니다. 고객별 통합 지원, 설치·운영·유지보수 범위는 별도로 정합니다.

설치 환경, 연동 대상, 운영 정책을 확인한 후 고객 환경에 맞는 구성을 정합니다. 서비스 고유의 업무 기능과 데이터 권한은 해당 서비스와 연계하여 적용합니다.

화면은 이해를 돕기 위한 예시이며, 제품 구성과 설정에 따라 달라질 수 있습니다. 상세 공급 범위는 도입 시 협의합니다.